

Azure Keyvault strategies

Wednesday, August 6, 2025 2:18 PM

Delegated Access via App Client ID

Recommended Strategy: Managed Identity + RBAC

For applications accessing Key Vault on behalf of users , Microsoft recommends using Managed Identities combined with Azure RBAC:

- System-assigned managed identity is ideal for single-instance apps.
- User-assigned managed identity is better for multi-instance or multi-slot deployments, avoiding repeated access grants

This setup allows the app to authenticate securely without storing credentials and simplifies access control across environments

Usage Pattern

- App negotiates OAuth tokens with third-party services.
- Tokens are stored in Key Vault using the app's identity.
- Users do not directly access Key Vault; the app acts on their behalf

Scalability Considerations

- With millions of users, rate limiting becomes a concern.
- Offloading frequent reads to Azure SQL or Storage Tables is recommended to reduce Key Vault load
- Use Azure Load Testing to validate performance under scale

Ad Hoc User Access

Recommended Strategy: Conditional Access + RBAC

For direct user access (e.g., developers or admins):

- Use Azure AD Conditional Access Policies to restrict access based on risk, location, or device compliance
- Assign RBAC roles like Key Vault Reader or Secrets User at the appropriate scope (subscription, resource group, or vault level)

Security Enhancements

- Enable multi-factor authentication for sensitive roles
- Use diagnostic settings to log access attempts and monitor failures

Mixing Access Policies and RBAC

Microsoft does not support mixing RBAC and Access Policies on the same vault:

- You must choose one model per vault.
- RBAC is the preferred model for centralized and scalable access control

Access Policies vs. Azure RBAC: Core Differences

Feature	Access Policies	Azure RBAC
Scope	Data plane only	Management + data plane
Granularity	Vault-level permissions	Role-based, scoped to vault, resource group, subscription
Compatibility	Legacy model	Recommended model since May 2023

Identity Types Users, groups, service principals All Azure AD identities including managed identities

Integration No PIM or deny assignments Integrated with PIM, supports deny assignments

When to Use Access Policies

While Microsoft strongly recommends Azure RBAC for most scenarios, Access Policies may still be appropriate in specific legacy or constrained environments:

1. Azure Databricks Secret Scopes

- Azure Databricks currently supports Access Policies only for Key Vault-backed secret scopes.
- RBAC is not yet compatible with Databricks secret scopes, so Access Policies are required to grant workspace-level access

2. Legacy Applications or Tenants

- If your application or infrastructure was built before RBAC support was introduced (pre-2021), and refactoring is not feasible, Access Policies may be retained temporarily

3. Simplified Vault-Level Permissions

- For small-scale environments where fine-grained role assignments are unnecessary, Access Policies offer a simpler configuration model.

Limitations of Access Policies

- Security Risk: Users with Contributor roles can self-assign access policies, potentially leading to unauthorized access

- No Centralized Management: Each vault must be configured individually, making it hard to audit and scale
- No Support for Deny Assignments or PIM: Access Policies lack advanced security features available in RBAC

When to Use Azure RBAC

Microsoft recommends RBAC for nearly all modern use cases:

- Centralized access control across all Azure resources
- Scoped permissions at vault, resource group, or subscription level
- Integration with PIM for time-bound access
- Granular control over individual secrets, keys, and certificates

Important Notes

- Mixing RBAC and Access Policies is not allowed. **Once RBAC is enabled (`RbacAuthorizationEnabled = true`), Access Policies are disabled and cannot be used**
- Migrating from Access Policies to RBAC should be done carefully, especially in bulk scenarios. Microsoft provides PowerShell scripts and migration guidance